Rapport de Veille : L'Intelligence Artificielle dans la Cybersécurité

Licence 3 -Intelligence Artificielle (IFRI)

Groupe 5

-AFAGNIBO Mélon Joanès

-CHOGOU Donald

-FAKEYE Grâce-Priscille

-LOHENTO Loan

Sous la supervision de :

Mme Marianne BALOGOUN

Année académique : 2026-2027

Ce rapport présente la synthèse d'une veille sur l'intelligence artificielle et la cybersécurité (477 articles), l'évaluation des sources par la grille CRAAP, puis la chaîne de veille automatisée qui a produit ce corpus, avec ses choix d'outils et leurs limites.

Introduction

L'intelligence artificielle générative est désormais utilisée des deux côtés de la cybersécurité : par des attaquants pour industrialiser certaines techniques, par des éditeurs et des équipes de défense pour automatiser la détection et la réponse. Le sujet produit un volume considérable de publications, mêlant études techniques, reportages, communiqués d'éditeurs et reprises d'une même dépêche. Distinguer ce qui est documenté de ce qui relève de l'annonce commerciale (l'"AI-washing") est le premier enjeu d'une veille sérieuse.

La question directrice est la suivante : quelles sont les évolutions dans le domaine de la cybersécurité à l'ère de l'IA, ou en rapport avec l'IA ? Elle se décline en deux interrogations. Que dit le corpus collecté sur l'état de la menace et de la défense liées à l'IA ?

Le corpus analysé compte 477 articles uniques, datés du 4 février au 14 octobre 2026 (470 d'entre eux d'octobre 2026) et rédigés à 99,8 % en anglais. Il constitue donc un instantané récent et anglophone, non une série temporelle. Les résultats sont consultables sur l'observatoire en ligne : elfuegox.github.io/Veille_IA_Cybersecurite.

Plan

Le développement suit les trois points demandés, puis une conclusion :

1. **Synthèse de la veille** : ce que le corpus documente sur l'IA offensive, les attaques contre les IA et les agents, le code généré, l'IA défensive et la gouvernance, avec des extraits d'articles du corpus.
2. **Sources et évaluation CRAAP** : composition du corpus, fonctionnement de la grille, résultats, et fiabilité de la grille elle-même.
3. **Chaîne de veille automatisée** : collecte, traitement, diffusion, outils retenus, raisons de ces choix et limites constatées.

La conclusion dresse le bilan et formule des recommandations.

I. Synthèse de la veille

Les articles du corpus sont rangés dans cinq sous-thèmes. Nous les définissons d'abord, puis nous donnons le classement des articles, avant de lire chaque sous-thème à travers quelques articles.

1.1 Les cinq sous-thèmes

Code	Sous-thème	Définition
S1	IA offensive	Usage de l'IA par les attaquants (phishing, exploits, logiciels malveillants).
S2	Attaques contre les IA	Attaques visant les modèles, les agents et leur infrastructure (injection d'instructions, empoisonnement, failles).
S3	Sécurité du code généré	Failles introduites par les assistants de programmation.
S4	IA défensive et SOC	Usage de l'IA pour détecter et répondre aux attaques, y compris les offres commerciales.
S5	Gouvernance et régulation	Cadres juridiques, supervision, conformité et gestion des risques.

1.2 Classement des articles

Sur 477 articles, 375 ont reçu un sous-thème ; 102 n'en ont pas (surtout des articles écartés ou non évalués). L'IA défensive occupe plus de huit articles classés sur dix.

Sous-thème	Articles	Part des articles classés	dont jugés fiables
S4 – IA défensive et SOC	319	85,1 %	129
S5 – Gouvernance et régulation	20	5,3 %	17
S2 – Attaques contre les IA	17	4,5 %	17
S1 – IA offensive	15	4,0 %	10
S3 – Code généré	4	1,1 %	4

1.3 Lecture par sous-thème

Les articles ci-dessous ont été relus, sauf mention contraire.

S1 – IA offensive

- XBOW : une chaîne d'exploitation Chrome construite en six jours par quatre chercheurs pilotant l'IA. La source est un éditeur, l'article est « À vérifier » (7/11).
- The Hacker News : des malwares glissent des instructions aux outils d'analyse par IA (technique « AI-Analysis Evasion » de Cisco Talos).
- RTÉ, Reuters, The Guardian : avertissement d'Anthropic sur de possibles « vers IA » (titres seulement, pages non relues).

S2 – Attaques contre les IA (17 articles sur 17 fiables)

- Malwarebytes : des e-mails cachent des consignes à l'assistant IA, par exemple changer les coordonnées de paiement d'un fournisseur (« À vérifier », 8/11).
- The Record : une faille de Vercel Sandbox permet de faire fuir des données ; aucun correctif publié.
- MemForm : l'empoisonnement de la mémoire des agents touche cinq interfaces testées sur six modèles, les défenses restant partielles.
- The Hacker News : exécution de code à distance dans LMCache (CVE-2026-105192), une faille d'infrastructure plus que de modèle.

S3 – Code généré : seulement 4 articles, dont trois préprints arXiv. La faible part vient probablement des mots-clés de collecte plus que d'un faible enjeu.

S4 – IA défensive et SOC : le moins bien noté (40,4 % de fiables, 33,5 % « À vérifier », 26,0 % écartés).

- Sygnia : un communiqué sans mesure indépendante, présent en trois copies notées 8, 8 et 9 sur 11 selon le site de diffusion.
- Help Net Security : sur 112 bugs réels, un modèle arrête le crash dans environ 90 % des cas mais ne passe les tests des mainteneurs que dans environ 61 %.

S5 – Gouvernance et régulation : Gizmodo, relayant Reuters, rapporte que les régulateurs bancaires américains et européens interrogent les banques sur leurs agents IA (approbation humaine, limites de pouvoir, arrêt d'urgence). Sources anonymes.

1.4 Lecture d'ensemble et limites

- Le corpus documente surtout des **risques liés aux agents et à l'infrastructure d'IA**, pas des attaques offensives entièrement autonomes.
- Le **discours commercial** pèse lourd dans S4, dont la qualité moyenne est la plus faible.
- Le corpus est un **instantané** (470 articles sur 477 d'octobre 2026), presque entièrement anglophone.
- **Un seul sous-thème par article** : chaque article a reçu le sous-thème qui le domine, alors qu'il peut relever de plusieurs. Un article sur un agent IA détourné par e-mail touche à la fois S1 et S2, par exemple. Les effectifs par sous-thème sont donc des ordres de grandeur, non des partitions strictes.

II. Sources et évaluation (grille CRAAP)

Le corpus mêle des sources de nature très différente. Les évaluer avec une grille explicite évite de juger chaque article « à l'instinct » et rend le tri reproductible.

2.1 Composition des sources

Les préprints d'arXiv forment la première source (121 articles, 25,4 %), loin devant la presse spécialisée : The Hacker News (26), Cybersecurity Insiders (16), Reuters (15), BleepingComputer (7), Microsoft (6), Yahoo Finance (6), CNBC (5). Le corpus contient aussi des communiqués d'éditeurs, des sites institutionnels et quelques contenus issus de réseaux sociaux (YouTube, Instagram, LinkedIn), entrés par les alertes Google.

La disponibilité du texte complet est un second critère de qualité de la source. La collecte a abouti pour 268 articles (56,2 %) ; 153 (32,1 %) sont restés au stade du lien de redirection Google, 23 ont échoué en HTTP, 23 ont été bloqués par `robots.txt` et 10 sont vides. Près de 44 % des articles ont donc été évalués sans lecture intégrale.

2.2 La grille CRAAP adaptée

La grille universitaire CRAAP (Currency, Relevance, Authority, Accuracy, Purpose) a été transposée en un score sur 11 points, défini dans un fichier de configuration. Le calcul est d'abord déterministe (dates, listes de sources d'autorité, expressions régulières) ; un modèle de langage peut compléter les critères d'exactitude et de neutralité.

Note de pertinence	**Condition**
3	IA et cybersécurité sont le sujet central (titre ou chapeau) et l'article apporte un fait concret (incident, étude, vulnérabilité, produit, chiffres).
2	Les deux domaines sont développés dans le texte, mais pas centraux, ou peu de faits (opinion, généralités).
1	Lien faible : un seul domaine développé, simple mention, ou texte surtout marketing.
Exclu	Sans rapport avec le thème (hors échelle).

Critère (colonne)	**2 points**	**1 point**	**0 point**
Actualité (craap_actualite)	Moins de 6 mois	6 à 18 mois	Plus ancien ou date introuvable
Pertinence (craap_pertinence)	Pertinence 3	Pertinence 2	Pertinence 1

Critère (colonne)	2 points	1 point	0 point
Autorité (craap_autorite)	Auteur identifié et source reconnue	Source identifiée, auteur absent (ou blog, éditeur)	Anonyme ou source inconnue
Exactitude (craap_exactitude)	Faits vérifiables, sources citées (CVE, étude, chiffres)	Quelques éléments vérifiables	Affirmations sans preuve
Objectif (craap_objectif)	Informer ou analyser de façon neutre	Intérêt commercial visible	Promotionnel ou accrocheur

Classement final : **Fiable** à partir de 8/11, **À vérifier** entre 6 et 7, **Écarté** sous 6 ou si la pertinence est inférieure à 2.

2.3 Résultats

Niveau	Articles	Part du corpus
Fiable	178	37,3 %
À vérifier	116	24,3 %
Écarté	109	22,9 %
Non évalué	74	15,5 %

Trois constats ressortent. D'abord, les 74 articles non évalués sont tous des préprints arXiv, ce qui explique que seuls 35 d'entre eux apparaissent parmi les fiables (19,7 % des fiables, contre 25,4 % du corpus). Ensuite, les notes se concentrent entre 7 et 9 pour 78 % des articles évalués (313 sur 403) et seuls 12 atteignent 11/11 : la grille discrimine peu. Enfin, seuls 5 articles ont une reprise détectée par d'autres sources, ce qui limite l'usage du critère de notoriété.

2.4 Fiabilité de la grille : comparaison avec une évaluation humaine

Le projet a comparé les scores automatiques à une référence humaine de 19 articles, dont 9 seulement ont pu être rapprochés du corpus par leur URL.

Axe	Articles comparés	Accord exact	Accord à ±1 point	Biais machine − humain
Pertinence (0-3)	9	88,9 %	100 %	+0,11
Actualité (0-2)	6	100 %	100 %	0,00
Autorité (0-2)	9	22,2 %	100 %	−0,78
Exactitude (0-2)	9	22,2 %	100 %	−0,56

Axe	Articles comparés	Accord exact	Accord à ±1 point	Biais machine − humain
Objectif (0-2)	9	66,7 %	100 %	+0,33
Total (/11)	6	0 %	100 % à ±2 points	−1,50
Niveau final	6	100 %	non applicable	κ = 1,00

La machine est plus sévère que l'humain d'environ 1,5 point en moyenne, surtout sur l'autorité (elle exige un auteur nommé et une source de la liste blanche) et sur l'exactitude (note neutre sans texte intégral). Le niveau final coïncide sur les 6 articles comparés, mais cet échantillon est trop petit pour conclure à une concordance fiable.

2.5 Limites de la grille

- **Pondérations et seuils non calibrés** : le total sur 11 et les seuils 8 et 6 sont empiriques, sans validation statistique.
- **Contenu promotionnel mal repéré par les règles** : un texte commercial qui emploie un vocabulaire technique (« CVE », « mitigation ») peut obtenir les points d'exactitude ; à l'inverse, un article critique rédigé sans jargon est pénalisé.
- **Dépendance à la source de diffusion** : le communiqué Sygnia, présent en trois copies, est noté 8/11 sur deux d'entre elles et 9/11 sur la copie Yahoo Finance.
- **Texte intégral manquant** : l'exactitude tombe à 1/2 par défaut, ce qui gonfle mécaniquement la catégorie « À vérifier ».

III. Chaîne de veille automatisée

La chaîne tourne sur GitHub Actions, sans serveur ni base de données payante. Quatre rôles se partagent le travail (collecte, qualité, analyse thématique, restitution) autour d'un fichier unique, `data/articles.csv`, dont chaque colonne appartient à un seul rôle. Elle enchaîne des scripts numérotés :

1. **Collecte et extraction** : `01_collecte.py`, `02_extraction.py`.
2. **Qualité (CRAAP)** : `04_qualite.py`, `05_evaluer_qualite.py`.
3. **Classification et notoriété** : `06_classifier.py`, `07_cve.py`, `08_notabilite.py`.
4. **Diffusion** : `09_export_site.py`, puis le site web.

3.1 Collecte

- **Outils** : Python, `feedparser` (flux RSS d'actualité, de CERT-FR, d'arXiv, alertes Google), `trafilatura` (extraction du texte), `rapidfuzz` (dédoublonnage), GitHub Actions (exécution planifiée).
- **Pourquoi** : `feedparser` est le standard Python pour le RSS, rapide et gratuit ; `trafilatura` retire menus et bannières pour ne garder que le corps de l'article ; GitHub Actions exécute les scripts chaque jour sans hébergement. Le cron est décalé (`17 6,18 * * *`) pour éviter la congestion des horaires « pile ».
- **Résilience** : résolution des liens de redirection Google, signature de navigateur réaliste, lecture de `robots.txt`, cache `actions/cache` pour conserver les textes entre deux exécutions (le dossier `data/textes/` est exclu de Git).
- **Limites** : le corpus ne contient que ce que diffusent les flux ; les premières annonces sur les réseaux sociaux sont presque absentes. Les paywalls et protections anti-bot font échouer l'extraction, et 153 liens restent des redirections. Le texte intégral manquait au départ dans les étapes suivantes, car le dossier de textes n'existait pas dans le conteneur Actions : c'est le principal incident technique du projet.
- **Chaînes de recherche des alertes Google** : trois chaînes ont servi. Les deux alertes Google ont été converties en flux RSS, lus ensuite par feedparser ; la troisième est une requête générale.
- **Alerte 1, menaces liées à l'IA :** `("AI-powered" OR "adversarial AI" OR "prompt injection" OR "agentic AI" OR "autonomous agents") AND ("malware" OR "ransomware" OR "phishing" OR "exploit" OR "vulnerability" OR "cyber threat")`
- **Alerte 2, IA et cybersécurité :** `("artificial intelligence" OR "Intelligent system" OR "GEN AI" OR "LLM" "automation system" OR "deep learning" OR "AI" OR "Agents") AND ("cybersecurity" OR "numerical security" OR "cyberattack" OR "cyberdefence" OR "Malware")`
- **Chaîne 3, requête générale :** `("artificial intelligence" OR "machine learning" OR AI) (cybersecurity OR "cyber security")`
- **Mots-clés du filtre** : le filtre de pertinence exige les deux concepts, IA (AI-powered, agentic AI, prompt injection, LLM, autonomous agents, machine learning) et cybersécurité (malware, ransomware, phishing, exploit, vulnerability, cyberattack), en français et en anglais, et distingue le « ai » français de l'acronyme AI.

3.2 Traitement

- **Qualité** : grille CRAAP hybride (règles Python, listes en YAML, modèle Groq ou Gemini en option). Les règles filtrent d'abord, ce qui évite un appel de modèle pour un article hors sujet.
- **Classification** : l'API Gemini, à température 0, classe chaque article dans S1 à S5 et doit fournir une citation exacte de moins de 25 mots tirée du texte, ce qui limite les hallucinations. Le texte est encapsulé dans des balises XML pour neutraliser les instructions éventuellement présentes dans l'article.
- **Ancrage factuel** : détection des CVE par expression régulière et rapprochement avec le catalogue CISA KEV (vulnérabilités exploitées). Un score de notoriété de 0 à 11 combine reprises, présence KEV, entreprises citées et qualité CRAAP.
- **Limites** : la comparaison de titres par `rapidfuzz` (seuil 70) peut regrouper des événements distincts ou manquer des titres reformulés ; dans le corpus, seuls 5 articles ont une reprise détectée, et, parmi les six titres sur l'avertissement d'Anthropic, deux seulement ont une reprise enregistrée (2 et 1). Le modèle ne lit que les 500 premiers mots, et une température 0 ne garantit pas un résultat identique d'un jour à l'autre. Le projet prévoyait six sous-thèmes mais en applique cinq ; les libellés du site et du classifieur ont dû être harmonisés.

3.3 Diffusion

- **Outils** : `09_export_site.py` produit un fichier JSON statique ; le site utilise React 19, TanStack Router, Recharts et Tailwind CSS v4, hébergés sur GitHub Pages. Trois vues : tableau de bord, explorateur d'articles, rapport de synthèse avec export.
- **Pourquoi** : le filtrage se fait dans le navigateur, sans serveur ni latence, pour un coût d'hébergement nul.
- **Limites** : ce modèle convient à quelques centaines d'articles, mais pas à des dizaines de milliers (JSON à télécharger en entier). La recherche se limite à une correspondance de texte après normalisation des accents, sans recherche floue ni sémantique.

3.4 Synthèse des choix

Choix	Raison	Limite principale
CSV versionné dans Git comme base	Gratuit, lisible, tracé par commit	Pas de verrou en cas d'écritures simultanées ; tout est stocké en texte
`feedparser` et RSS	Simple, rapide, sans coût	Biais de sélection vers les sources qui publient des flux
`trafilatura`	Meilleure extraction du corps de l'article	Échecs sur paywalls et anti-bot
CRAAP en règles, LLM en option	Reproductible et peu coûteux	Pondérations arbitraires, règles contournables

Choix	Raison	Limite principale
Gemini avec citation exigée	Limite les hallucinations	Contexte limité à 500 mots, résultats non strictement déterministes
Site statique React	Rapide, sans serveur	Ne passe pas à grande échelle

3.5 Pistes d'amélioration

- Persister le texte intégral des articles et résoudre les redirections avant toute évaluation.
- Calibrer les seuils CRAAP sur un échantillon humain plus large que 19 articles.
- Remplacer la comparaison de titres par des plongements vectoriels pour mieux détecter les reprises.
- Ajouter des flux de réseaux sociaux et de sources francophones (un seul article en français dans le corpus).
- Passer à une base interrogée par API si le volume croît.

3.6 Organisation du travail

Le travail suit quatre phases. La phase 0 fixe les règles (schéma du CSV, dépôt, sous-thèmes S1 à S5, seuils, échantillon de 8 articles par personne). La phase 1 est parallèle : chacun produit sa partie de la chaîne. La phase 2 vérifie que les quatre morceaux fonctionnent ensemble sur l'échantillon. La phase 3 traite le déploiement du site et de tout le taf derrière ainsi que la rédaction du rapport.

Rôle	**Tâches principales**	**Rédige dans le rapport**
P1 : collecte et données	Flux RSS, extraction du texte, résumé court, doublons (rapidfuzz), workflow planifié	flux, extraction, filtrage ; annexes : sources et requêtes
P2 : qualité	Pertinence de 1 à 3, cinq critères CRAAP, liste des sources d'autorité, script de scoring, test contre notes humaines	pertinence et CRAAP ; annexe grille CRAAP ; limites et biais
P3 : analyse thématique	Sous-thèmes S1 à S5, prompt de classification avec citation, CVE et CISA KEV, notoriété, cas remarquables	classification ; par sous-thème ; §6 analyse transversale ; fiches de cas
P4 : restitution	Site, export des données, validation manuelle, graphiques, squelette du rapport, PDF final	Résumé ; bibliographie ; assemblage

Conclusion

La veille réalisée montre qu'un dispositif entièrement automatisé, sans serveur, peut collecter, filtrer et classer plusieurs centaines d'articles sur l'IA et la cybersécurité. Sur ce corpus de 477 articles, 178 sont jugés fiables ; le reste signale surtout la difficulté du domaine : un sous-thème défensif saturé par le discours commercial, et des analyses techniques qui viennent en grande partie de préprints.

Ce que la veille apprend, pour un responsable de la sécurité :

- Les risques documentés portent surtout sur les **agents IA** (injection d'instructions par e-mail, évasion de bac à sable, empoisonnement de mémoire) et sur l'**infrastructure de déploiement**, plus que sur des attaques offensives entièrement autonomes.
- Les actions à fort impact (paiement, changement de coordonnées) doivent rester soumises à une **validation humaine** par un canal distinct, et les permissions des assistants doivent être limitées, comme le rappellent Malwarebytes et les régulateurs bancaires cités.
- Face aux annonces d'éditeurs, il faut **demander ce que mesure le score** : base de comparaison, accès aux sources du projet, tests des mainteneurs, plutôt qu'un simple indicateur d'activité.

Le dispositif a aussi ses faiblesses, qu'il vaut mieux affirmer que masquer : un corpus anglophone et récent, une grille CRAAP aux seuils non calibrés et validée sur un échantillon très réduit, une détection des reprises quasi inopérante, et une dépendance au texte intégral que 44 % des articles n'ont pas fourni. Les pistes de la partie III (texte persistant, calibration, plongements, sources sociales et francophones) visent ces points. Les résultats restent consultables, et mis à jour automatiquement, sur l'observatoire en ligne.

Sources

Articles du corpus relus et cités

- XBOW, *XBOW built a Chrome full-chain exploit*
- The Hacker News, *Weekly Recap: Helpdesk 0-Days, Rogue Certs, ShinyHunters Arrest, AI-Fooling Malware and More*
- Malwarebytes, *Phishing emails are baiting your AI assistant*
- The Record, *Sandbox vulnerability gives rogue AI agents a path to escape and leak data, research says*
- Pan et al., *MemForm: Benchmarking Memory Formation Poisoning in LLM Agents*, arXiv:2610.14431
- Help Net Security, *AI vulnerability patching has a grading problem*
- Business Wire, *Sygnia Unveils Security Operations Center Hubs and Expands AI-Powered Cybersecurity Capabilities*
- Gizmodo, *Shifting AI Doomsday Predictions Reportedly Worry Banking Regulators*

Articles du corpus cités d'après leur titre seulement (page non relue)

- RTÉ, *AI could self-replicate across smart devices, Anthropic warns*

- The Guardian, *AI in your oven? Anthropic warns models 'months away' from self-replication on smart devices*
- arXiv, *Last Secure Code Benchmark: Is the Code You Vibe Secure?*

Projet et données

- Observatoire Veille IA & Cybersécurité
- Export public du corpus (`veille-ia-cybersecurite-public_5.csv`, 477 articles) et dossier de cadrage du projet, fournis par l'équipe : source des effectifs, des scores CRAAP, de la comparaison humain-machine et de la description technique de la chaîne.-+